

SOP: Vendor Onboarding and Offboarding

Document ID: SOP-VOB-013 Version: 2.0 Effective Date: 2025-11-15 Owner: Procurement & Enterprise Risk Management

Purpose

Defines the end-to-end process for bringing a new vendor into an active contractual relationship and formally closing out a vendor relationship at contract end, ensuring both procurement and risk requirements are met at each stage.

Part A — Onboarding

Step 1 — Intake and Risk Tier Determination

Business owner submits a vendor intake request specifying the scope of services and the type of data or system access required. Procurement, in coordination with Enterprise Risk Management, determines the vendor's risk tier per Vendor Risk Management Policy (POL-VRM-005) Section 2.

Step 2 — Tier-Appropriate Assessment

Based on the assigned tier: - **Tier 1:** Vendor must submit SOC 2 Type II report, complete a full security questionnaire, and undergo an initial security audit before contract execution. - **Tier 2:** Vendor must submit SOC 2 Type I (or equivalent) and complete the standard security questionnaire. - **Tier 3:** Vendor completes the standard security questionnaire only. - **Tier 4:** No additional assessment required beyond standard procurement intake.

Contracts cannot be routed for approval until the tier-appropriate assessment is complete and on file.

Step 3 — Sanctions and Watch List Screening

Procurement screens the vendor's legal entity name against applicable sanctions and watch lists before proceeding. A positive match requires escalation to Legal and halts onboarding pending resolution.

Step 4 — Insurance Verification

Vendor must provide certificates of insurance meeting the minimum coverage thresholds defined in POL-VRM-005 Section 6 for their assigned tier. Coverage below the required threshold must be remediated (increased coverage or a documented risk acceptance from the Chief Risk Officer) before contract execution.

Step 5 — Contract Drafting and Clause Verification

Contract must include all mandatory clauses per Procurement Policy (POL-PROC-001) Section 4, and the data privacy clause required by Information Security Policy (POL-SEC-002) if the

vendor will access Company data. Reference SOP: Contract Approval Process (SOP-CA-010) for the full approval routing procedure.

Step 6 — System Provisioning (if applicable)

For vendors requiring system access, IT provisions access strictly scoped to the minimum required for the contracted services, following the principle of least privilege. Access provisioning must not occur before contract execution.

Step 7 — Onboarding Confirmation

Procurement records confirmation that all prior steps are complete before the vendor is marked active in the vendor management system and the contract becomes the governing document for future invoice validation.

Part B — Offboarding

Step 1 — Offboarding Trigger

Offboarding is initiated upon contract expiration without renewal, termination for convenience, or termination for cause.

Step 2 — Access Revocation

IT revokes all system access within 24 hours of the offboarding trigger, as required by POL-VRM-005 Section 7. This applies regardless of the reason for offboarding.

Step 3 — Data Return or Destruction

Vendor returns or destroys all Company data within 30 days per POL-VRM-005 Section 7 and Data Retention and Records Management Policy (POL-DRM-006). For Tier 1 and Tier 2 vendors, written certification of destruction is required and must be retained per the retention schedule in POL-DRM-006.

Step 4 — Final Invoice Reconciliation

Finance confirms all outstanding invoices have been validated and paid, or formally disputed, before the vendor relationship is closed in the system. Any open disputes must be documented with a resolution owner and target date.

Step 5 — Risk Closure Review

Enterprise Risk Management conducts a closure review documenting any outstanding risk findings, open security incidents, or unresolved audit items associated with the vendor, per POL-VRM-005 Section 7.

Step 6 — Records Retention

All contract, invoice, and risk assessment records associated with the vendor relationship are retained per the schedule in POL-DRM-006 — records are not deleted at offboarding, only the active vendor relationship is closed.

Common Failure Points

- Contract executed before required security assessment is complete
- System access provisioned before contract execution (Step 6, Part A)
- Access not revoked within the 24-hour window at offboarding
- Missing destruction certification for Tier 1/2 vendor offboarding
- Records deleted at offboarding instead of following the retention schedule